Dr. Rob van Eijk
Future of Privacy Forum

Leiden Legal Tech Program

Kwaliteitscontrole en rapportages

Online, 24 september 2021

Universiteit Leiden
Leiden Centre of Data Science

FUTURE OF PRIVACY FORUM

© 2021, R. van Eijk, BY-NC-SA

Onderwerpen voor vandaag

- Kwaliteitscontrole, hoe doe je dat?
- Hoe maak je kwaliteit in een juridische context meetbaar?
- Een antwoord op de vraag: waarom meet je?
- Rapportages ten behoeve van juridische verdedigbaarheid.

Measuring Legal Quality [1]

- "Selecting metrics is a design process that comes about by understanding how a product or service is used my a majority in the market."
- "With standardized quality metrics in place, components can be used based on a value curve allowing someone to piece together an appropriate level of quality within a given cost framework."

Dolin, Ron A., Measuring Legal Quality (2017). http://dx.doi.org/10.2139/ssrn.2988647

Measuring Legal Quality [2]

- Example: deposition witness files
- "Define relevant in the case as those documents put in front of a witness by opposing counsel during a deposition."
- "Let's assume that the witness is too busy to have time to be prepped for all the documents in the witness file."
- "The highest quality witness file would consist of all and only such documents, with a quality score of 1.0."
- "Even though a quality score of 1.0 is improbable, the point is to set a metric that creates a competitive landscape based on a desired goal."

Dolin, Ron A., Measuring Legal Quality (2017). http://dx.doi.org/10.2139/ssrn.2988647

Kwaliteitscontrole en rapportages [1]

- Het meetbaar maken van de kwaliteit van juridische processen ligt ten grondslag aan **rapportages**.
- Het meetbaar maken is op zichzelfstaand ook onderhevig aan een proces van verbetering.
- Een Capability Maturity Model (CMM) is een beschrijving van de mate waarin een organisatie in staat is haar **kwaliteitcontrole** te verbeteren.

Kwaliteitscontrole en rapportages [2]

- Cirkel van Deming (PDCA: Plan-Do-Check-Act).
- Six Sigma (bijv. in procesoptimalisatie van productie)
  - DMAIC: Define-Measure-Analyze-Improve-Control
  - DMADV: Define-Measure-Analyze-Design-Verify

https://nl.wikipedia.org/wiki/Six_Sigma#/media/Bestand:Standard_deviation_diagram_micro.svg

Discussie [1]

Gegeven de voorgaande introductie:

Waarom meet je de kwaliteit van juridische processen?

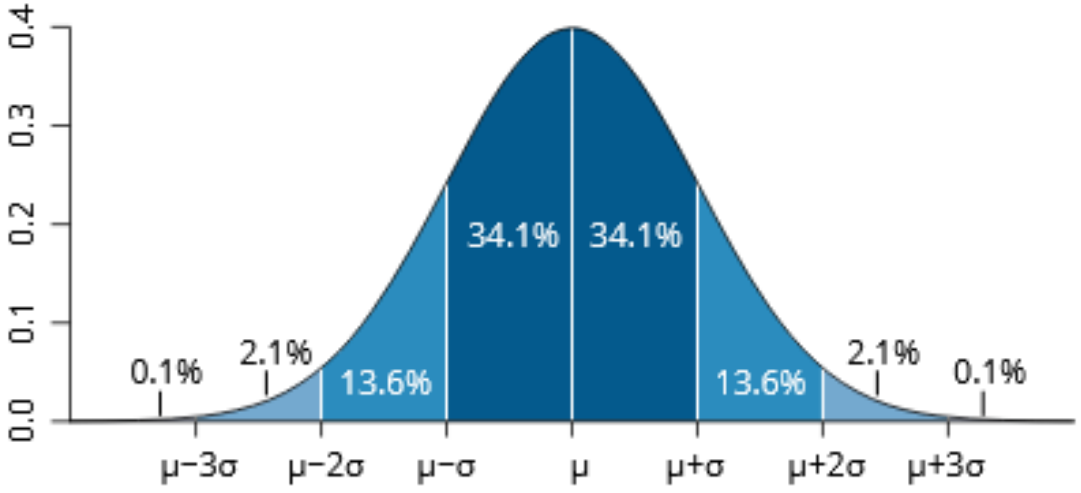
Discussie [2]

- “Benchmarks of key metrics allow for the stratification of service quality.”
- “Benchmarks allow for a focus on *what, not how*, legal work is produced.” (emphasis added)
- “Benchmarks provide a framework for continual quality improvement.”
- “Benchmarks allow for the prvention and discovery of problems with continuous measurements, especially where such assessments is made automated.”

Dolin, Ron A., Measuring Legal Quality (2017). http://dx.doi.org/10.2139/ssrn.2988647

Kwaliteitscontrole en rapportages [2]

- Doel: idealiter valt 99.99966% van hetgeen gemeten wordt binnen de bepaalde goedkeurings-marge.
- In statistische termen komt dat overeen met zes standaardafwijkingen binnen een normale verdeling.



https://nl.wikipedia.org/wiki/Six_Sigma#/media/Bestand:Standard_deviation_diagram_micro.svg

CNIL Data Protection Management Maturity Self Assessment

- A model, which quantifies the rigour and formalities with which activities related to data protection management are managed.
- Transposes the notion of maturity levels to data protection.
- Well defined in ISO/IEC 21827 and ANSI 'SSI Maturity' Guide.

https://www.cnil.fr/fr/la-cnil-propose-une-autoevaluation-de-maturite-en-gestion-de-la-protection-des-donnees

CNIL Da nt Maturit

- A model, w formalities protection
- Transpose protection
- Well defin Maturity' (

Levels		Features
0	**No or incomplete practice**	Nothing is done about data protection. Data protection is not known or supported within the organization and the need is not recognized.
1	**Informal practice** (some isolated actions)	Actions are carried out using basic practices. They are implemented informally and in response to isolated requests, with no real commitment from the organization's leadership and no real coordination among those who implement these actions.
2	**Repeatable and ongoing practice** (repeatable actions)	☐ The actions are carried out by a person with data protection skills. ☐ Actions are planned. ☐ Some practices are formalized, which allows duplication and reuse (possibly by another person). ☐ Data protection is monitored by the organization's leadership, but the entire business is far from being involved. ☐ Qualitative measures are carried out (simple indicators of results, e.g. consideration of data protection in a particular project).
3	**Defined process** (standardization of practices)	☐ The actions are carried out in accordance with a defined process (e.g.: use of methods), standardized (common to the whole organization) and formalized (existence of documentation). ☐ The people carrying out the actions have the appropriate skills for the process. ☐ The organization supports the process (i.e., provides the resources, facilities, and training necessary to make it work). ☐ The process is well understood by both management and workers.
4	**Controlled process** (quantitative measurement and correction of defects)	☐ The process is coordinated throughout the selected area and for each run. ☐ Quantitative measurements are regularly made (in terms of performance, e.g. proportion of projects considering data protection). ☐ The measurements made (qualitative and quantitative indicators) are analysed (e.g. someone is responsible for studying the indicators and proposing an analysis and an action plan). ☐ Improvements are made to the process based on the analysis of the measurements made.
5	**Continuously optimized process** (improvement continued)	☐ The process is dynamically adapted to the situation (directly integrated improvements and changes). ☐ The analysis of the measurements carried out is defined, standardised and formalised. ☐ Process improvement is defined, standardized and formalized. ☐ The evolution of the process is traced.

https://www.cnil.fr/fr/la-cnil-propose-ur nees

CNIL Da… nt

Levels	Features
0 No or incomplete practice	Nothing is done about data protection. Data protection is not known or supported within the organization and the need is not recognized.
1 Informal practice (some isolated actions)	Actions are carried out using basic practices. They are implemented informally and in response to isolated requests, with no real commitment from the organization's leadership and no real coordination among those who implement these actions.

	1 Informal practice	2 Practice repeatable and followed	3 Defined process	4 Controlled process	5 Process continuously optimized
Define and implement implementation of procedures on data protection	Some good practices are implemented on an ad hoc basis (e.g., minimization of collection or deletion of obsolete data, disclosures).	Documents related to data protection (best practices, rules, examples, etc.) are shared. There is documentation (e.g.: charter for the use of IT resources) containing rules on data protection.	Documentation formal (e.g., data protection policy), approved by the Management Committee, is communicated to all staff. Procedures are formalized and communicated to all staff. The rules are applied.	An annual review of policies and procedures is carried out. Indicators are produced (e.g., on (e.g. on the implementation of the rules, on the difficulties encountered, on their effectiveness, etc.).	Policies and procedures are updated as soon as potential improvements are identified.

Maturity …

	indicators and proposing an analysis and an action plan). ☐ Improvements are made to the process based on the analysis of the measurements made.
5 Continuously optimized process (improvement continued)	☐ The process is dynamically adapted to the situation (directly integrated improvements and changes). ☐ The analysis of the measurements carried out is defined, standardised and formalised. ☐ Process improvement is defined, standardized and formalized. ☐ The evolution of the process is traced.

https://www.cnil.fr/fr/la-cnil-propose-ur… …nees

CNIL Da… nt

Levels	Features
0 No or incomplete practice	Nothing is done about data protection. Data protection is not known or supported within the organization and the need is not recognized.
1 Informal practice (some isolated actions)	Actions are carried out using basic practices. They are implemented informally and in response to isolated requests, with no real commitment from the organization's leadership and no real coordination among those who implement these actions.

	1 Informal practice	2 Practice repeatable and followed	3 Defined process	4 Controlled process	5 Process continuously optimized
Managing security risks	Basic security measures are in place (e.g.: clearances, securing workstations, etc.).	Guidelines are used to select and implement security measures (e.g. CNIL personal data security guide, internal security policy, etc.).	Data protection impact assessments (DPIAs) include a security risk assessment. A method is used to assess the risks of processing operations that are likely to result in high risks to data subjects and to address them in a proportionate manner. Risk studies are the subject of action plans.	The implementation of the action plans is verified in terms of effectiveness and efficiency. Residual risks are monitored by indicators.	Risk studies and action plans are reviewed annually. An active watch is kept on vulnerabilities related to data carriers and corrective action is taken in the event of an impact on the information system.

Maturity …

	indicators and proposing an analysis and an action plan). ☐ Improvements are made to the process based on the analysis of the measurements made.
5 Continuously optimized process (improvement continued)	☐ The process is dynamically adapted to the situation (directly integrated improvements and changes). ☐ The analysis of the measurements carried out is defined, standardised and formalised. ☐ Process improvement is defined, standardized and formalized. ☐ The evolution of the process is traced.

https://www.cnil.fr/fr/la-cnil-propose-ur… …nees

CNIL Da… nt

Levels	Features
0 No or incomplete practice	Nothing is done about data protection. Data protection is not known or supported within the organization and the need is not recognized.
1 Informal practice (some isolated actions)	Actions are carried out using basic practices. They are implemented informally and in response to isolated requests, with no real commitment from the organization's leadership and no real coordination among those who implement these actions.

	1 Informal practice	2 Practice repeatable and followed	3 Defined process	4 Controlled process	5 Process continuously optimized
Managing data breaches	Incidents are reported. Corrective measures are sometimes taken. A data breach notification is sometimes made to the CNIL.	Incident management, implemented in a manner that is includes data breaches. Measures corrective measures are systematically taken. Provision is made for communication to those whose data have been breached in a way that could result in a high risk.	A data breach management procedure is formalized and implemented systematically. All violations are recorded in a dedicated register. Following a data breach, an action plan is in place to reduce the risk of a recurrence.	The implementation of corrective actions is verified. Indicators for monitoring data breaches are created and communicated (e.g. in the annual review).	An assessment of the violations is regularly carried out in order to identify and implement measures to improve data security. Data breach management feeds into risk studies (e.g. AIPD). Automatic trace management ensures that data breaches are detected as quickly as possible.

Maturity …

	indicators and proposing an analysis and an action plan). ☐ Improvements are made to the process based on the analysis of the measurements made.
5 Continuously optimized process (improvement continued)	☐ The process is dynamically adapted to the situation (directly integrated improvements and changes). ☐ The analysis of the measurements carried out is defined, standardised and formalised. ☐ Process improvement is defined, standardized and formalized. ☐ The evolution of the process is traced.

https://www.cnil.fr/fr/la-cnil-propose-ur… …nees

Discussie

- Een WOB-verzoek als voorbeeld voor kwaliteitscontroleDataset: 100 Gb emailbestand (.PST)
- Wat zit daar zoal in?
- Bewerkingen: verrijken, vertalen, uitpakken, sorteren, filteren, ontdubbelen etc.
- Wat blijft er na bewerken over?
- Hoe kun je met rapportages verantwoorden wat je niet vrijgeeft?

Rapportage voorbeelden

- Collection error report
- Processing error report
- Inclusion report
- Exclusion report
- Chain of custody report
- Legal review report
- PII/Personal data report

J. Scholtes (2021)

Dank voor uw aandacht

Contact: rvaneijk@fpf.org